

Incident Management Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-006

Version 1.0 | Effective: 20 Feb 2026

Document Control Page

Policy Title	Information Security Incident Management Policy
Policy ID	ISIMP-006
Version	1.0
Author	Information Security Manager
Owner	Chief Information Security Officer (CISO)
Reviewer	Senior Security Analyst / Data Protection Officer (DPO)
Approver	Chief Executive Officer (CEO)
Current Review Date	February 18, 2026
Next Review Date	February 18, 2027
Approval Date	February 18, 2026
Domain (ISO/IEC 27002:2022)	Organizational controls

Sub-domain (ISO/IEC 27002:2022)	5.24 Information security incident management planning and preparation 5.25 Assessment and decision on information security events 5.26 Response to information security incidents; 5.27 Learning from information security incidents; 5.28 Collection of evidence
--	--

Approver: Chief Executive Officer

Signature: _____

Date: 18th Feb 2026

Email Approval: "I approve Information Security Policy v1.0" -
CEO@fortisaid.com, 18/02/2026

1. Introduction

Fortisaid is a healthcare organisation operating in the UK, delivering services, handling sensitive personal health information (including special category data under the UK GDPR), and Data Protection Act 2018, and critical clinical systems. Effective incident management is essential to protect patient confidentiality, maintain service continuity, minimise harm from breaches, and comply with regulatory obligations such as UK GDPR, Data Security and Protection Toolkit (DSPT) and ISO 27002

2. Purpose

This policy establishes a structured, consistent, and effective approach to planning for, detecting, assessing, prioritizing, responding to, learning from, reporting, and documenting information security incidents. It ensures quick containment, appropriate reporting, and continuous improvement to reduce future risks.

3. Scope

This information security incident management policy applies to all Fortisaid employees, contractors, temporary staff, volunteers, third parties, and systems processing health and care information. It covers all information security events/incidents affecting the confidentiality, integrity, or availability of information assets, including cyber incidents, data breaches, unauthorised access, malware, ransomware, and physical security events impacting information.

4. ISO 27002:2022 Alignment

ISO DOMAIN	ISO SUB DOMAIN	CONTROL NUMBER	HOW THE POLICY ADDRESSES IT
Information Security Incident	Planning and Preparation	5.24	Defines processes, roles, and

Management			responsibilities for detecting, and managing information security incidents within Fortis Aid.
Information Security Incident Management	Assessment and Decision	5.25	Establishes steps for assessing incidents, determining severity, and deciding on appropriate response actions ..
Information Security Incident Management	Response	5.26	Provides guidance for containment, eradication, and recovery procedures to ensure swift restoration of healthcare systems and data integrity.
Information Security Incident Management	Learning from Information Security Incidents	5.27	Captures lessons learned from incidents to prevent recurrence and improve response processes.
Information Security Incident Management	Collection of Evidence	5.28	Ensures proper evidence handling and preservation to support investigations or legal actions.
Information Security Incident Management	Business Continuity Integration	5.29	Links incident response with continuity plans to maintain healthcare services during major disruptions

5. Policy Statements / Requirements

5.1 Incident Detection and Reporting

- All staff must promptly report suspected or confirmed security incidents to the IT Service Desk.
- Security systems must continuously monitor for abnormal activity.
- Incident reports must include time, type, and potential impact.

5.2 Incident Response and Escalation

- The Incident Response Team must assess and prioritize incidents based on impact and urgency.
- Escalation must follow predefined communication channels.
- Critical healthcare system incidents must be addressed immediately to ensure patient safety.

5.3 Post-Incident Review and Improvement

- Lessons learned must be documented and reviewed within seven days of incident closure.
- Evidence must be collected and preserved according to legal requirements.
- Findings must inform training and updates to prevent recurrence.

6. Roles and Responsibilities

ROLES	RESPONSIBILITIES
Chief Executive Officer (CEO)	Approves the policy and allocates resources for implementation
Chief Information Security Officer (CISO)	Owens the policy, oversees compliance, and coordinates response efforts.
Incident Response Lead	Manages incident handling, documentation, and communication.
Clinical Systems Director	Ensures continuity and protection of patient-care systems during incidents.
All Staff	Reports incidents immediately and follows defined response procedures.

7. Compliance and Enforcement

7.1 Monitoring Activities:

- **Frequency:** Quarterly
- **Responsible Role:** Chief Information Security Officer (CISO)
- **Evidence Stored:** Incident reports, review logs, and response summaries

7.2 Non-Compliance:

Violations may lead to disciplinary action or reporting to regulatory bodies.

7.3 Exceptions:

Any exceptions must be approved in writing by the CISO and reviewed annually.

8. Training and Awareness

- Mandatory completion of policy-specific training within 30 days of joining.
- Annual refresher training for all staff.
- Role-specific training for privileged roles and clinical staff.

9. Review and Revision

- This policy will be reviewed annually or following significant incidents or regulatory changes.
- **Next scheduled review:** 18 February 2027.